Automotive Security

Prof. Dr. Christoph Krauß

Summer Term 2023

h_da
HOCHSCHULE DARMSTADT
UNIVERSITY OF APPLIED SCIENCES
fbi
FACHBEREICH INFORMATIK

Chapter 6: Secure Electric Mobility

Contents

- Introduction
- Background
- Communication Protocols
- (Possible) Attacks
- ISO 15118
- Summary

Introduction

Motivation I

- E-Mobility is an important technology for reducing emissions
- E-Mobility is in the fast lane
  - 1.013.009 registered battery electric vehicles (EV) in Germany (January 1, 2023)
  - Additionally, 864.712 plug-in hybrid cars (January 1, 2023)
- Information and communication technology enables smart charging
  - Plug and Charge (PnC)
  - Satisfy user requirements
  - Demand response and load management
  - Vehicle-to-Grid (V2G)

electrive.com
industry service for electric mobility

Menu

Automobile >

Jan 9, 2023 - 11:26 am

Over one million purely electric cars now on German roads

BEV | EUROPE | GERMANY | SUBSIDIES

The German Institute for Economic Research (DIW) has reported that the mark of one million pure electric cars in Germany has been crossed. According to the report, the mark was passed in the new record month of December 2022.

In the last month of 2022, Germany's old – higher – environmental bonus and innovation premium was still valid, and 104,325 new electric cars were newly registered. The DIW says that the reduction in the electric car subsidies as of the New Year accounts for the strong increase in December.

As of January this year, an electric car purchase came with a maximum of 4,500 euros from the state, whereas up until the end of last year, the subsidy was 6,000 euros plus the manufacturer's share, which is half of the state's support.

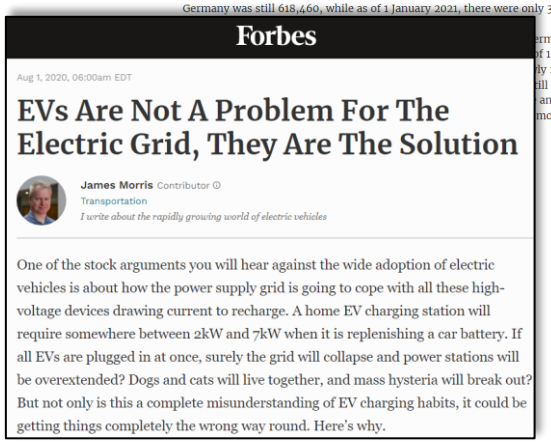
The one million mark reached accounts only for purely battery electric cars and not plug-in hybrids recorded in December. As it stands, PHEVs also set a record in December, as the environmental bonus for these motor types was abolished completely at the turn of the year.

The German Federal Motor Transport Authority has not yet published figures on the number of cars with a cut-off date of 1 January 2023 but as of 1 October 2022, already recorded 840,645 electric cars. If the monthly BEV registrations in October, November and December are added to this figure, the result is 1,038,731 electric cars. If the million mark was indeed cracked, fewer than 38,731 electric cars must have been deregistered in the last quarter.

The increase is startling when compared to the previous two years. As of 1 January 2022, the number of electric cars in Germany was still 618,460, while as of 1 January 2021, there were only 309,083 electric cars on German roads.

rmany's so-called 'environmental bonus', the DIW
f 15 million electric cars can be achieved by 2030. As the
ly registered every month from now on to make the
ill only 32,000 electric cars newly registered per month
announced that they will only offer electric cars in the
monthly registrations.

Source: https://www.electrive.com/2023/01/09/over-one-million-purely-electric-cars-now-on-german-roads/ Based on numbers of the German KBA.



Forbes

Aug 1, 2020, 06:00am EDT

EVs Are Not A Problem For The Electric Grid, They Are The Solution

James Morris Contributor
Transportation
I write about the rapidly growing world of electric vehicles

One of the stock arguments you will hear against the wide adoption of electric vehicles is about how the power supply grid is going to cope with all these high-voltage devices drawing current to recharge. A home EV charging station will require somewhere between 2kW and 7kW when it is replenishing a car battery. If all EVs are plugged in at once, surely the grid will collapse and power stations will be overextended? Dogs and cats will live together, and mass hysteria will break out? But not only is this a complete misunderstanding of EV charging habits, it could be getting things completely the wrong way round. Here's why.

Source: https://www.forbes.com/sites/jamesmorris/2020/08/01/evs-are-not-a-problem-for-the-electric-grid-they-are-the-solution/

Motivation II

- New security and privacy threats
  - Operational disturbances
    - Prevent charging
    - Influence power grid
  - Safety-adverse effects
    - Triggering fire event
    - Disabling safety measures
  - Financial damage
    - Charge to another's account / for free
    - Damage EV battery or reduce lifetime / capacity
    - Damage CS
  - Privacy loss
    - Generation of movement profiles
    - Analysis of time and location of the used CSs

Source: https://insideevs.com/news/423581/severe-electric-car-fire-explosion-charging/

Forbes

As More EVs Hit The Road, Blackouts Become Likely

Oliver Wyman Contributor

Oliver Wyman Contributor Group

Aerospace & Defense

Exploring transport & travel's transformative ideas & technologies

POST WRITTEN BY

Members of the Energy Practice at Oliver Wyman

Oliver Wyman's Thomas Fritz, Andrew Perry, Aditya Ranjan, Joerg Staeglich, and Curtis Underw produce this article.

Power outages may not be as severe if cars are encouraged to charge at power stations.

Source: https://www.forbes.com/sites/oliverwyman/2019/05/15/as-more-evs-hit-the-road-blackouts-become-likely/?sh=628ea8f9dc30

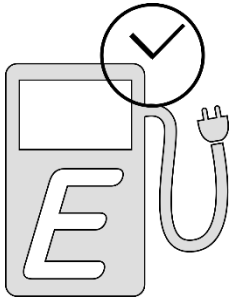
Chaos Computer Club hacks e-motor charging stations

2017-12-27 00:43:00, 46halbe

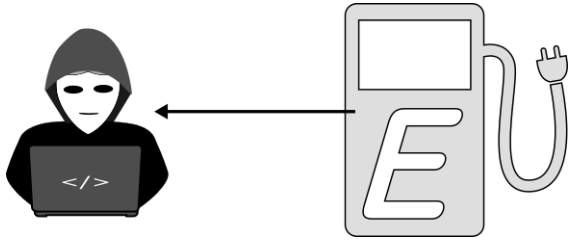
Currently, the infrastructure for charging electronic vehicles is rolled out in Germany – once again without paying much attention to IT security. The convenient charging cards are currently so insecure that it is not advisable to use them. It is trivially possible to charge your car while having someone else unknowingly being forced to pay. Nearly all charging cards are affected by this vulnerability. Charging network providers that issue these cards have refused to fix the security problems, despite being given several months pre-warning. The details of the vulnerabilities will be presented in detail today at the 34th Chaos Communication Congress at 12:45 in Leipzig.

Source: http://ccc.de/en/updates/2017/e-motor

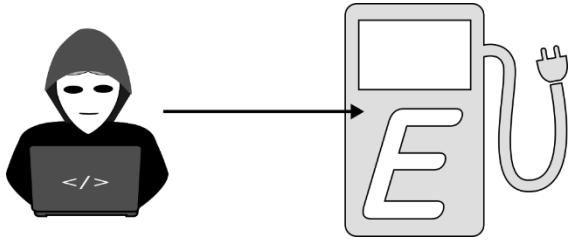
Security and Privacy Threats – Examples at the Charging Station



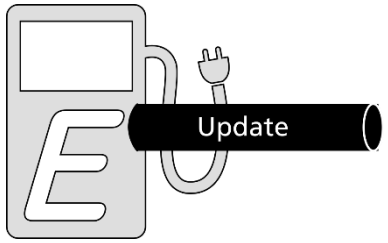
Long Lifetime



Unauthorized data extraction



(Firmware) Manipulation



Secure Update

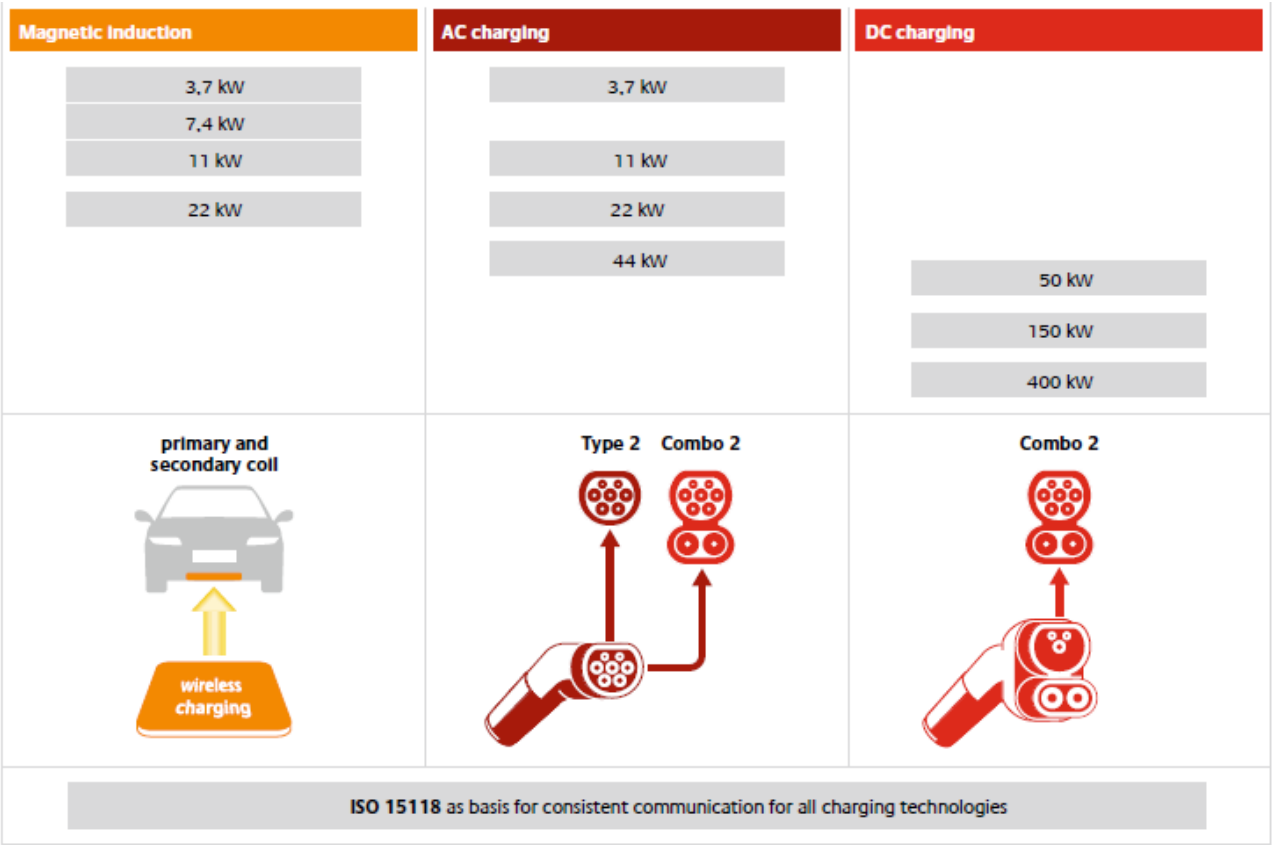
Privacy

Background

Charging Options

- Two general charging options
  - Conductive (AC or DC)
  - Inductive
- Different charging interfaces, e.g., Type 2, Combo 2, CHAdeMO (Japan)

Combo 2 (left), Type 2 (right)



Overview of the charging options and their typical charging capacities [NPE17]

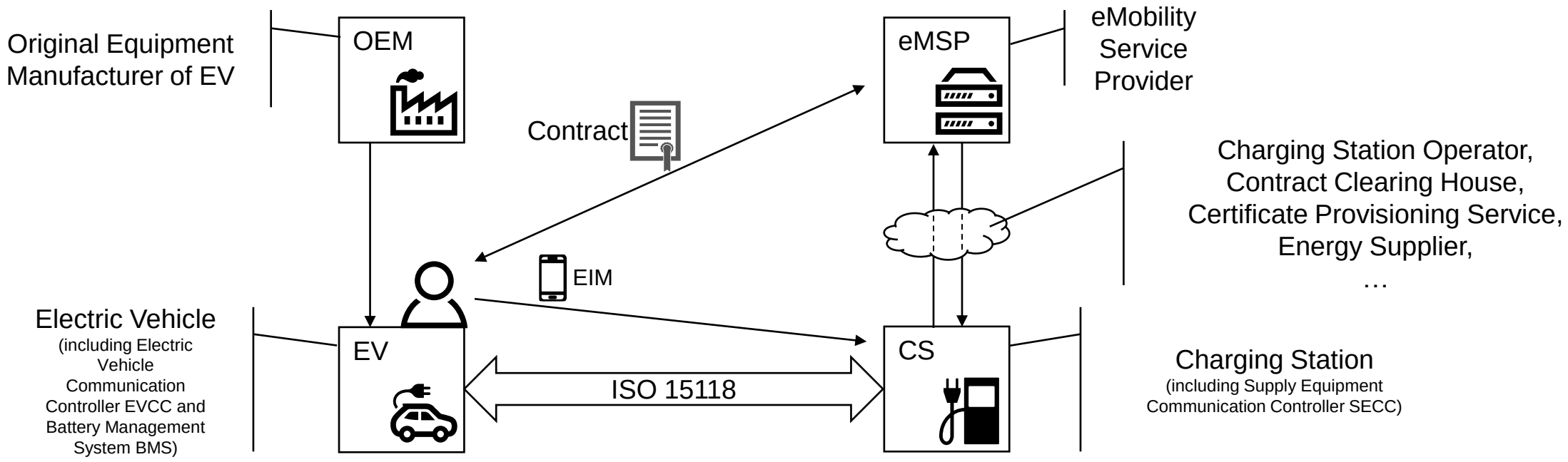
Payment Options – Examples

Source: Entega

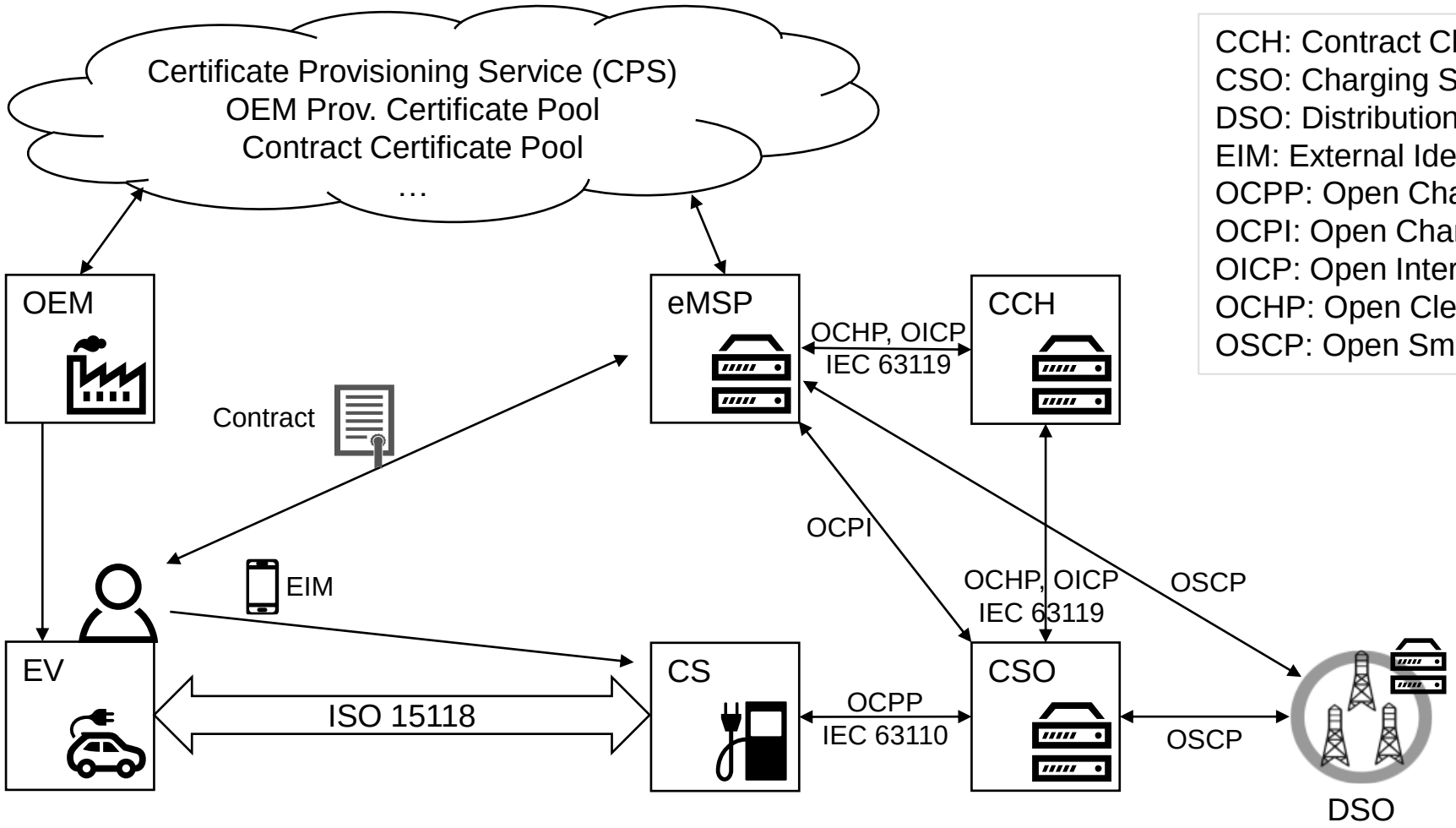
- Charging costs are included in fees for other services
  - Examples: parking costs, leasing fee for the car
- Charging card
  - Payment with a dedicated NFC/RFID card/token (postpaid or prepaid)
  - Roaming between providers requires the use of a roaming platform such as Hubject
  - Currently mostly used approach
- Cashless payment using EMV reader
  - Existing credit or debit cards can be used
- Smartphone app
  - Customer downloads an app, registers, and provides payment information
  - A charging session is started, e.g., by scanning an QR code or by using NFC of the phone
- Plug and Charge (PnC) using ISO 15118
  - Direct authentication and authorization of a vehicle
  - Driver needs just to plug in the charging cable without requiring any further intervention

Source: innogy

Typical Charging Architecture – Simplified



Typical Charging Architecture – More Details



CCH: Contract Clearing House
CSO: Charging Station Operator
DSO: Distribution System Operator
EIM: External Identification Means
OCPP: Open Charge Point Protocol
OCPI: Open Charge Point Interface
OICP: Open InterCharge Protocol
OCHP: Open Clearing House Protocol
OSCP: Open Smart Charging Protocol

Entities of the Charging Architecture I

- Owner / Driver
  - Has a contract for charging her EV with an e-Mobility Service Provider (eMSP)
- Electric Vehicle (EV)
  - Can store sensitive data, e.g., contract certificates
  - Equipped with Electric Vehicle Communication Controller (EVCC)
  - Equipped with Battery Management System (BMS) for management of electric and thermal functions of the battery
- Charging Station (CS) / Charge Point (CP) / Electric Vehicle Supply Equipment (EVSE)
  - Stores sensitive data, e.g., metering, credentials
  - Equipped with Supply Equipment Communication Controller (SECC)
  - May be able to communicate with EV, e.g., using IEC 61851 or ISO 15118
  - Communicates with CSO (and other backends), e.g., using OCPP
- Charging Station Operator (CSO) / Charge Point Operator (CPO)*
  - Operates and manages one or more CSs
  - Gets energy from an energy supplier (often CSOs are subsidiaries of energy suppliers)
  - Communicates with eMSP for billing the eMSP's customer for charging at her CSs

* Secondary Actor (SA)

Entities of the Charging Architecture II

- Original Equipment Manufacturer (OEM)*
  - Producer of the EV
  - Equips the EV with initial vehicle credentials
- e-Mobility Service Provider (eMSP) / Mobility Operator (MO)*
  - Makes contracts with customers (vehicle owner)
  - Issues credentials, e.g., RFID card, charging contract certificate
  - Communicates with CSO and other backends
- Contract Clearing House (CCH)*
  - Enables roaming, i.e., use of foreign charging networks
  - Routes billing information between contract parties
  - Communicates with CSOs and eMSPs
- Certificate Provisioning Service (CPS)*
  - Entity for issuing / signing contract certificates on behalf of an eMSP (ISO 15118)
- Energy Supplier*
  - Usually a Distribution System Operator (DSO)
  - Delivers energy via the CS to the EV

* Secondary Actor (SA)

Communication Protocols

(Relevant) E-Mobility Communication Protocols

Protocol	Transport	Security	Privacy	Communication Partners
ISO 15118	V2GTP, EXI	TLS	none	EV - CS
ISO 15118-20	V2GTP, EXI	TLS	none	EV - CS
NEMA EVSE 1.2	ISO 14443	ISO 7816-4	none	RFID card - CS
OCPP 1.6-S	HTTP, XML, SOAP	none	none	CS - CSO
OCPP 1.6-J	HTTP, JSON over Websockets	TLS	none	CS - CSO
OCPP 2.0.1	HTTP, JSON over Websockets	TLS	none	CS - CSO
OCPI 2.2	HTTP, JSON, REST	TLS	none	eMSP - CSO
OCHP 1.4	SOAP	WS-Security	none	eMSP - CCH, CSO - CCH
OICP 2.2	HTTP, SOAP, REST	none	none	eMSP - CCH, CSO - CCH
OSCP 2.0	JSON / REST	TLS	none	CSO - DSO

Protocols and their Relations

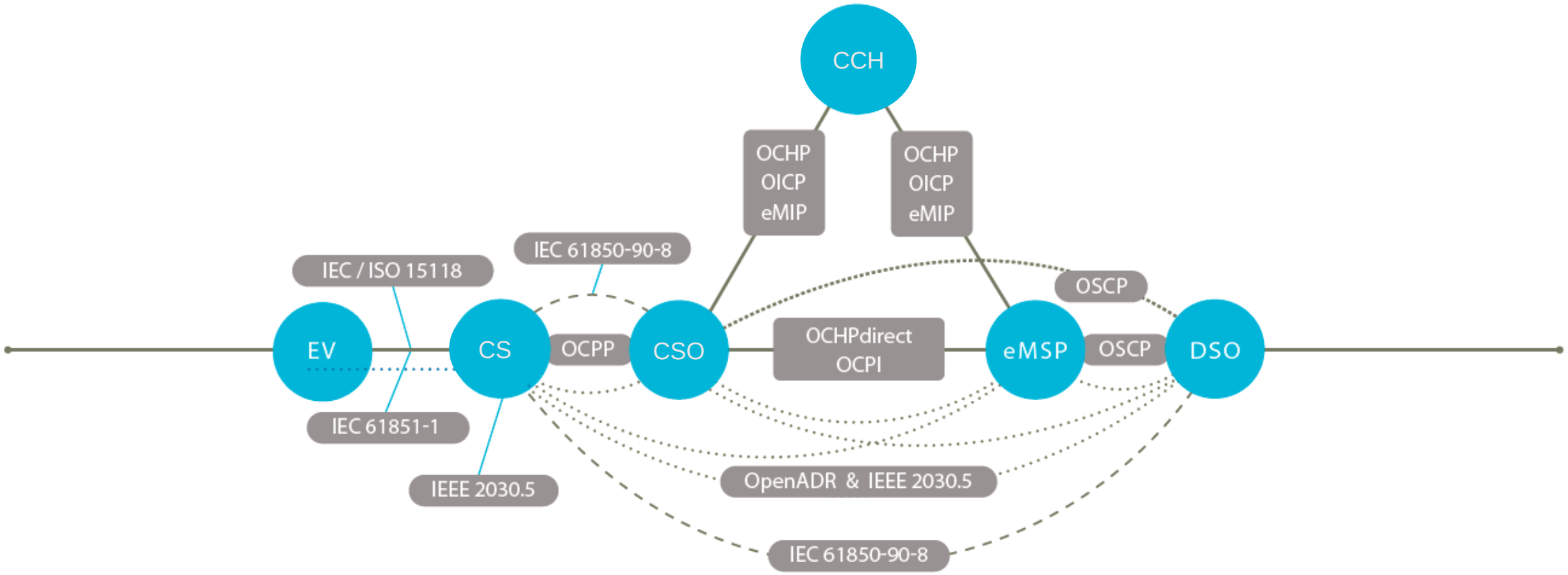


Figure adapted from [El17]

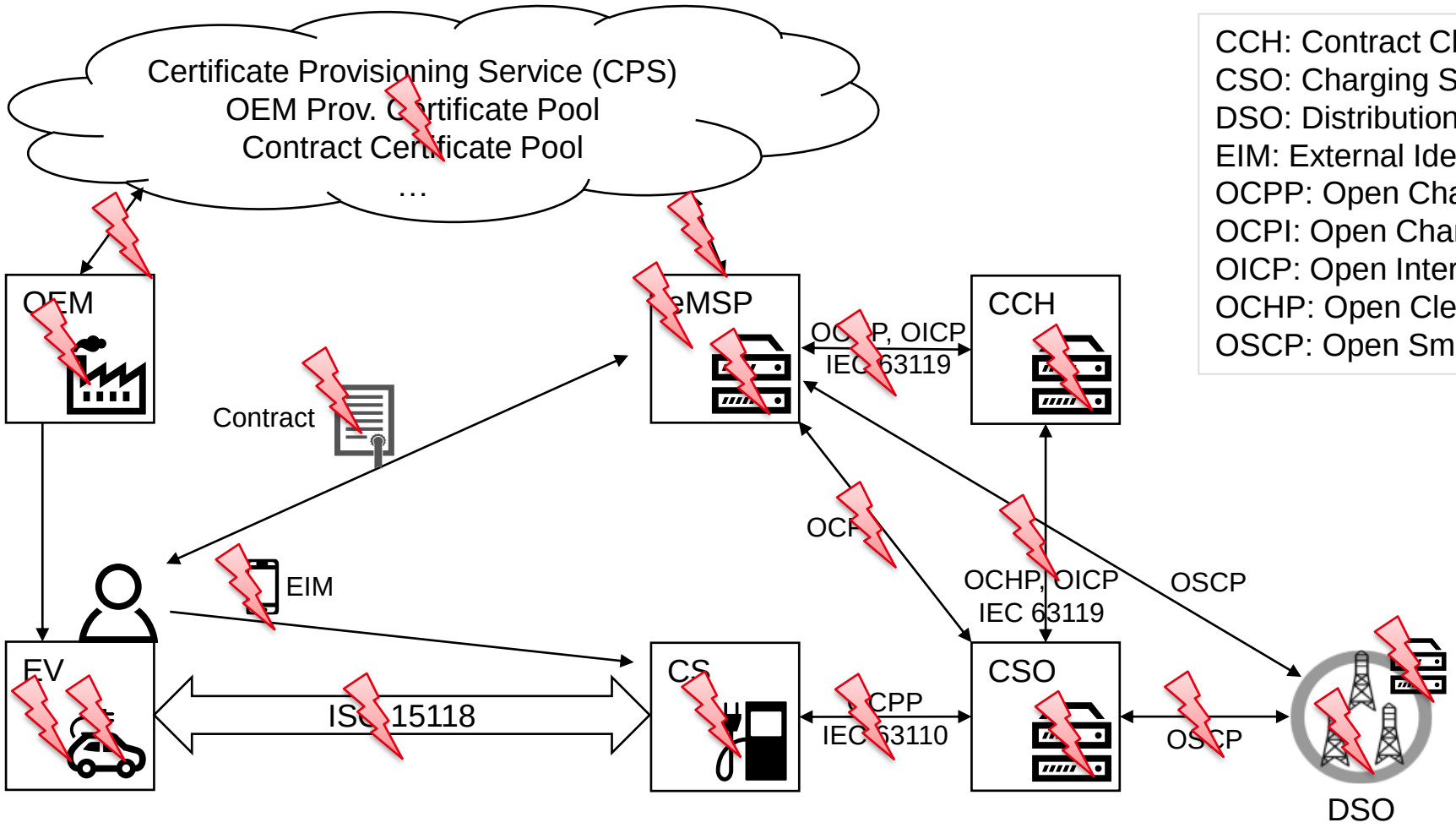
Use Cases Supported by the Protocols

	OSCP	OpenADR	OCPI v0.4	IEEE 2030.5	OCPP	61850-90-8	OCHP	OCPI 2.1	OICP	eMIP	IEC 61851	ISO 15118
PROTOCOL	Smart Charging				CS <> CSO		Roaming				EV <> CS	
Authorize charging session			•		•		•	•	•	•		•
Billing					•		•	•	•	•		
EV Charging											•	•
Handle registration		•		•				•				
Manage grid	•	•		•	•	•						
Operate Charge Point					•	•						
Provide charge point information			•				•	•	•	•		
Reservation			•		•		•	•	•			•
Roaming			•				•	•	•	•		
Smart Charging	•	•	•	•	•	•	•			•	•	•

Figure adapted from [El17]

(Possible) Attacks

Attack Points



CCH: Contract Clearing House
CSO: Charging Station Operator
DSO: Distribution System Operator
EIM: External Identification Means
OCPP: Open Charge Point Protocol
OCPI: Open Charge Point Interface
OICP: Open InterCharge Protocol
OCHP: Open Clearing House Protocol
OSCP: Open Smart Charging Protocol

Attack Point: EIM

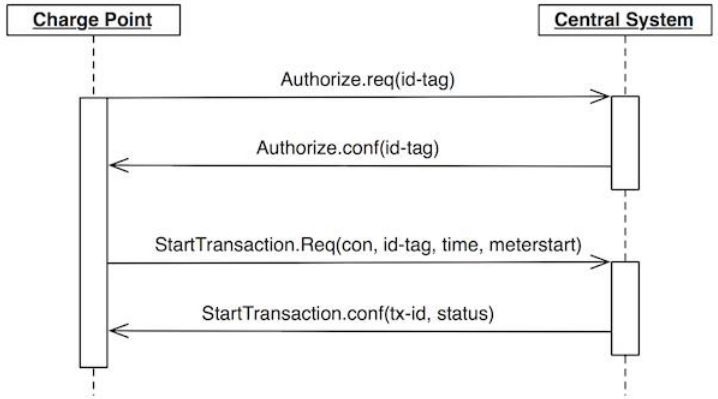
- Attacks on Charging Cards [Dal17]
  - Insecure charging cards
    - Use of (public) card ID (ID Tag) for billing
    - Use of broken Mifare Classic chip
  - Charging cards can be easily copied
  - IDs can be guessed
- Threat
  - Charge to another's account
  - …

```
$ xxd newmotion.mfd
00000000: XXXX XXXX XXXX XX88 4400 c820 0000 0000
00000010: 0000 0000 0000 0000 0000 0000 0000 0000
00000020: 0000 0000 0000 0000 0000 0000 0000 0000
00000030: ffff ffff ffff ff07 8069 ffff ffff ffff
00000040: 0000 0000 0000 0000 0000 0000 0000 0000
00000050: 0000 0000 0000 0000 0000 0000 0000 0000
00000060: 0000 0000 0000 0000 0000 0000 0000 0000
00000070: ffff ffff ffff ff07 8069 ffff ffff ffff
[...]
000003c0: 0000 0000 0000 0000 0000 0000 0000 0000
000003d0: 0000 0000 0000 0000 0000 0000 0000 0000
000003e0: 0000 0000 0000 0000 0000 0000 0000 0000
000003f0: ffff ffff ffff ff07 8069 ffff ffff ffff
```

Contents of NewMotion Charging Card [Dal17]

Attack Point: Backend Communication

- Attacks on (insecure) backend communication [Dal17]
  - Communication between CS and CSO often via OCPP 1.5 / 1.6
  - Unencrypted transmission of ID Tag
- Threats
  - Charge to another's account (or for free)
  - Prevent charging
  - Analyze user (privacy)
  - …

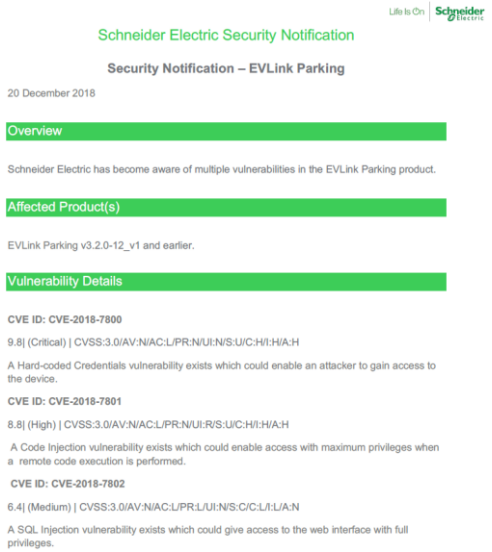



```
<s:complexType name="AuthorizeRequest">
    <s:sequence>
        <s:element name="idTag" type="tns:IdToken" minOccurs="1" maxOccur
s="1"/>
    </s:sequence>
</s:complexType>
```

```
<s:simpleType name="IdToken">
    <s:restriction base="s:string">
        <s:maxLength value="20"/>
    </s:restriction>
</s:simpleType>
```

Attack Point: Charging Station

- Attacks exploiting CS vulnerabilities
  - Insecure USB update mechanism [Dal17]
  - Insecure authentication, e.g., use of vehicle MAC address [Dal17]
  - Hard-coded credentials and other vulnerabilities [Sch18]
  - …
- Threats
  - Influence power grid
  - Charge to another’s account (or for free)
  - Prevent charging
  - Analyze CS user (privacy)
  - …



Life Is On | Schneider Electric

Schneider Electric Security Notification

Security Notification – EVLink Parking

20 December 2018

Overview

Schneider Electric has become aware of multiple vulnerabilities in the EVLink Parking product.

Affected Product(s)

EVLink Parking v3.2.0-12_v1 and earlier.

Vulnerability Details

CVE ID: CVE-2018-7800

9.8| (Critical) | CVSS:3.0/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

A Hard-coded Credentials vulnerability exists which could enable an attacker to gain access to the device.

CVE ID: CVE-2018-7801

8.8| (High) | CVSS:3.0/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

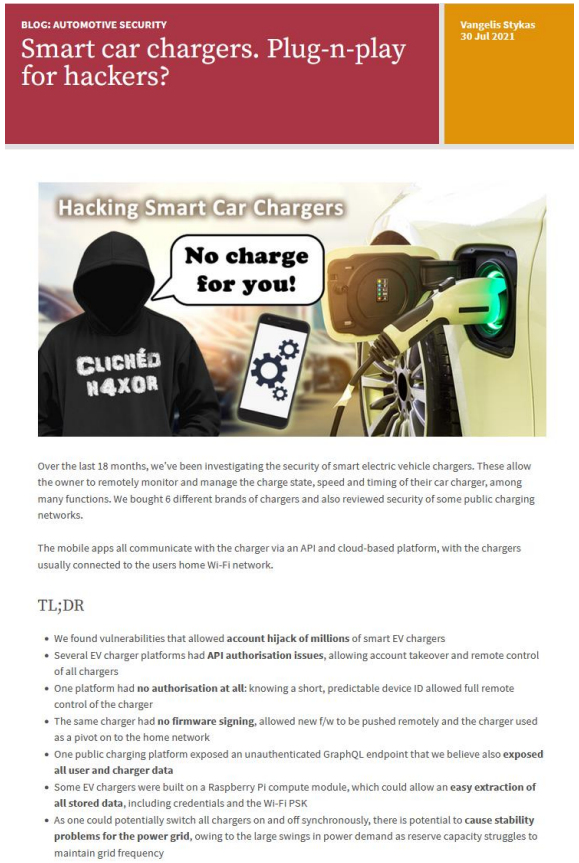
A Code Injection vulnerability exists which could enable access with maximum privileges when a remote code execution is performed.

CVE ID: CVE-2018-7802

6.4| (Medium) | CVSS:3.0/AV:N/AC:L/PR:L/UI:N/S:C/C:L/I:L/A:N

A SQL Injection vulnerability exists which could give access to the web interface with full privileges.

Security Notification – EVLink Parking



BLOG: AUTOMOTIVE SECURITY

Smart car chargers. Plug-n-play for hackers?

Vangelis Stykas
30 Jul 2021

Over the last 18 months, we've been investigating the security of smart electric vehicle chargers. These allow the owner to remotely monitor and manage the charge state, speed and timing of their car charger, among many functions. We bought 6 different brands of chargers and also reviewed security of some public charging networks.

The mobile apps all communicate with the charger via an API and cloud-based platform, with the chargers usually connected to the users home Wi-Fi network.

TL;DR

- We found vulnerabilities that allowed **account hijack of millions** of smart EV chargers
- Several EV charger platforms had **API authorisation issues**, allowing account takeover and remote control of all chargers
- One platform had **no authorisation at all**: knowing a short, predictable device ID allowed full remote control of the charger
- The same charger had **no firmware signing**, allowed new f/w to be pushed remotely and the charger used as a pivot on to the home network
- One public charging platform exposed an unauthenticated GraphQL endpoint that we believe also **exposed all user and charger data**
- Some EV chargers were built on a Raspberry Pi compute module, which could allow an **easy extraction of all stored data**, including credentials and the Wi-Fi PSK
- As one could potentially switch all chargers on and off synchronously, there is potential to **cause stability problems for the power grid**, owing to the large swings in power demand as reserve capacity struggles to maintain grid frequency

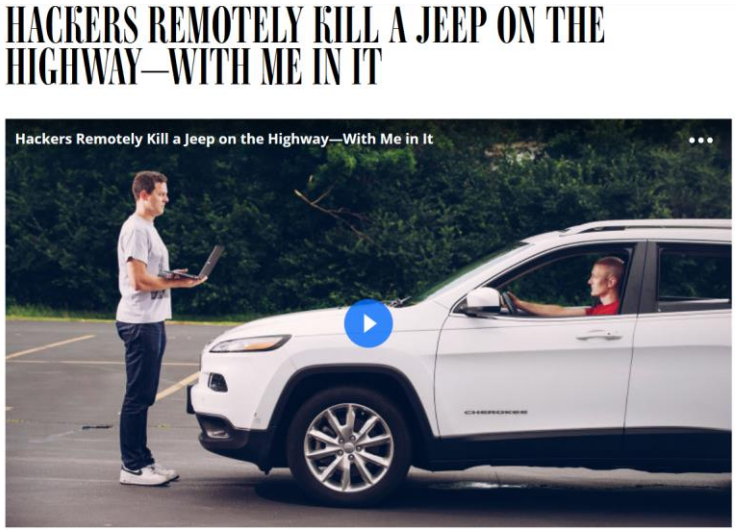
Source: https://www.pentestpartners.com/security-blog/smart-car-chargers-plug-n-play-for-hackers/

Insecure USB Update Attack on Keba P30 [Dal17]

Attack Point: EV

- Attacks
  - Vulnerability in the infotainment system of a Tesla Model 3 in 2019
  - Vulnerability in the infotainment system of Volkswagen and Audi in 2018
  - Remote hack of a Tesla Model S in 2016
  - Insecure smartphone app for Nissan Leaf in 2016
  - Remote hack of a Jeep Cherokee in 2015
  - …
- Threats
  - Charge to another's account
  - Share a contract
  - Drain battery
  - Influence power grid
  - …

Nissan Leaf App / VIN-based Authentication



Source: http://www.wired.com/2015/07/hackers-remotely-kill-jeep-highway/

Attack Point: EV-CS Communication

- Attacks
  - Shortcomings of ISO 15118 (cf. for example [BVW18])
    - TLS not mandatory
    - No requirements for secure key generation and storage
    - No end-to-end security
    - No real cryptographic agility, fixed cipher suites
      - TLS_ECDH_ECDSA_WITH_AES_128_CBC_SHA256
      - TLS_ECDHE_ECDSA_WITH_AES_128_CBC_SHA256
  - Skimming / Man-in-the-Middle attacks
  - Wireless attacks on Wi-Fi communication in case of inductive charging
- Threats
  - Charge to another's account
  - Share a contract
  - Prevent charging
  - Analyze user (privacy)
  - …

MitM Attack Preventing Charging

Source: https://www.swri.org/press-release/electric-vehicle-charging-cybersecurity-vulnerabilities

Attack Point: Backend Systems

- None of the current PnC protocols define privacy-preserving measures
  - Entities gain knowledge of personal data which is not required for their operation
  - No compliance with European GDPR rules
- Privacy threats
  - Generation of movement profiles
  - Analysis of time and location of the used CPs
- Privacy extensions currently only proposed from researchers, e.g.,
  - PnC with Direct Anonymous Attestation (DAA) [ZSZK18]
  - Extension for entire charging infrastructure and further services [KLK22]

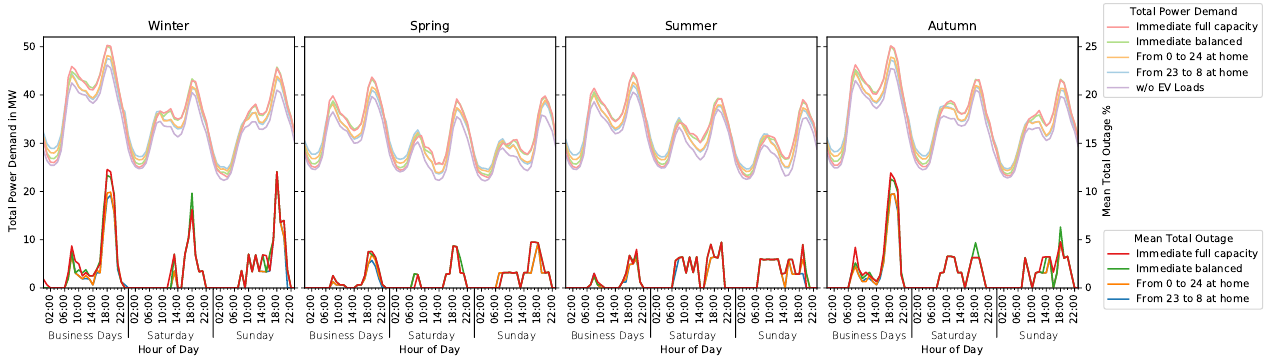
	CP	CPO	CCH	eMSP
Credential Provisioning				
Provisioning Certificate	(X)	(X)	X	X
Contract Credentials	(X)	(X)	(X)	X
Charge Authorization				
eMAID	(X)	(X)	(X)	X
Location	X	X	(X)	(X)
Time	X	X	X	X
Charge Billing (CDRs)				
eMAID	(X)	(X)	(X)	X
Location	X	X	(X)	(X)
Transaction Information	X	X	(X)	X

X = actor knows this personal data; arguably required for operation
(X) = actor knows this personal data; arguably not required for operation

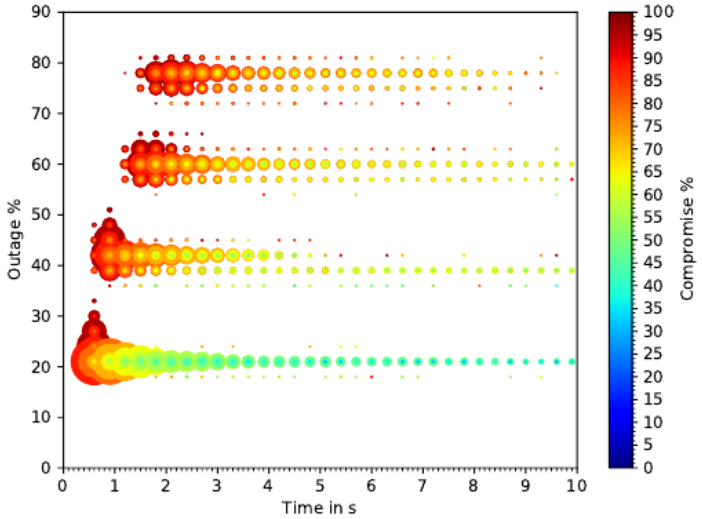
Example: Personal Data in EV Charging Infrastructure [KLK22]

Attack Point: Power Grid

- Impact of e-mobility-based attacks on power grid resilience [KK21]
  - Simulation and analysis how e-mobility-based attacks can cause power outages
    - At what times of a day are attacks most easily carried out?
    - How many compromised CSs and EVs are needed for successful attacks?
    - How much time is available to respond to attacks before a power outage occurs?



Base Grid Load Compared to Outage % in MV Oberrhein Scenario 2030 at 50% Compromise



Outage over Time at Different Compromise %

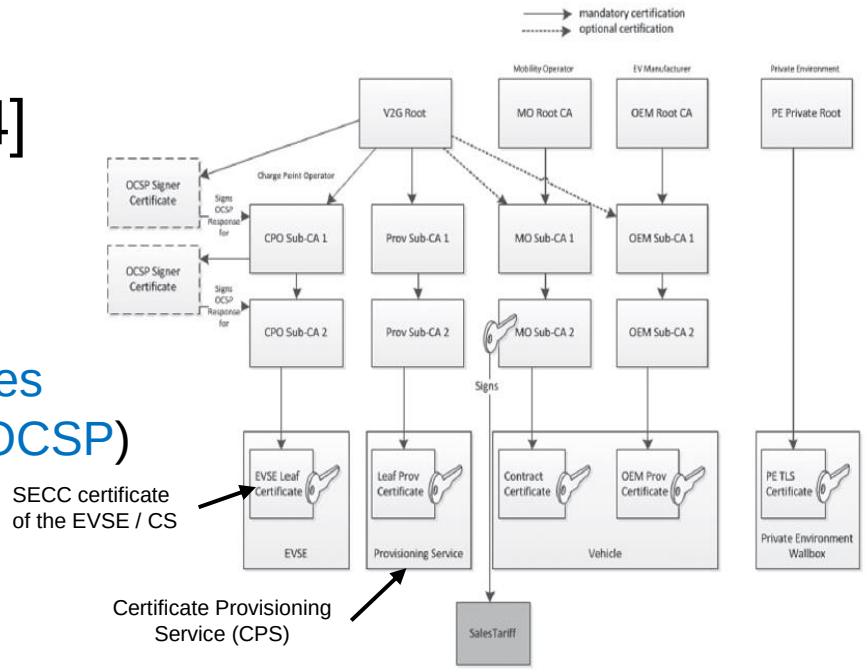
ISO 15118

Overview

- ISO 15118 standard published in 2014 [ISO14]
  - Vehicle to grid communication interface
    - Dynamic exchange of information between EV and CS
      - “Grid-friendly” negotiation of charging parameter, schedule etc.
      - Focus on Power-line communication (PLC) for wired AC and DC charging
    - Supports EIM and Plug-and-Charge (PnC)
  - Security is based on PKI, digital certificates, and TLS
- ISO 15118-20 (2nd Edition of ISO 15118) published in 2022 [ISO22]
  - Wireless power transfer (WTP) for inductive charging
  - Bidirectional power transfer (BTP)
  - Wireless communication
  - Improved security

Security Concept and Issues of ISO 15118

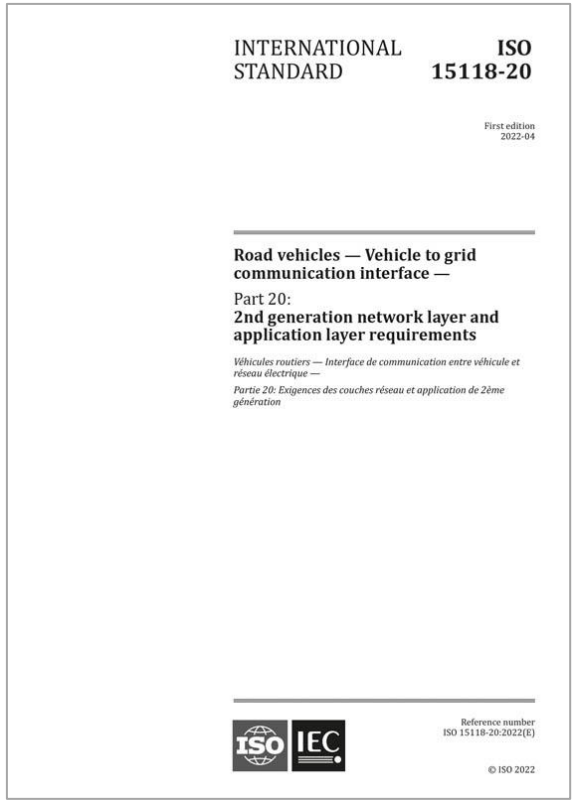
- Security Concept of ISO 15118 (Edition 1) [ISO14]
  - PKI and digital certificates
  - TLS 1.2 channel between EV and CS
    - Unilateral TLS authentication of CS
    - EV authentication on application layer with XML signatures
    - Certificate status via Online Certificate Status Protocol (OCSP) and Certificate Revocation List (CRL)
  - Communication with SAs secured on application layer
- Security Issues
  - No End-2-End Security
  - No cryptographic agility, fixed cipher suites, CBC issues …
    - `TLS_ECDH(E)_ECDSA_WITH_AES_128_CBC_SHA256`
  - TLS not mandatory (only for PnC and Value Added Services (VAS))
  - Protection of cryptographic keys with HSMs only recommended
  - No privacy-preserving measures defined
  - …



ISO 15118 PKI and Certificates [ISO14]

Security Concept of ISO 15118-20 – Overview I

- Similar Security Concept of ISO 15118-20 (Edition 2) [ISO22]
  - PKI and certificate concept mostly identical to Edition 1
  - Mandatory use of TLS 1.3 between EV and CS
    - Mutual authentication of CS and EV
  - Certificate status via OCSP and Certificate Revocation List (CRL)
  - XML Signatures on application layer
    - Used, e.g., for contract authentication
  - Definition of firewall functionality
  - Protection of cryptographic keys recommended
    - Use of HSM / automotive-qualified TPM 2.0
    - Approach for installing contract certificates (based on [FKK20a])
  - Random number generator best practices
  - Data link layer security for WiFi
    - WPA3-Enterprise or WPA2-Enterprise (IEEE 802.1X with EAP-TLS)
    - For securing communication before TLS channel establishment
  - Backwards compatibility to Edition 1 (use of TLS 1.2 etc.)


INTERNATIONAL STANDARD

ISO 15118-20

First edition
2022-04

Road vehicles — Vehicle to grid communication interface —

Part 20:
2nd generation network layer and application layer requirements

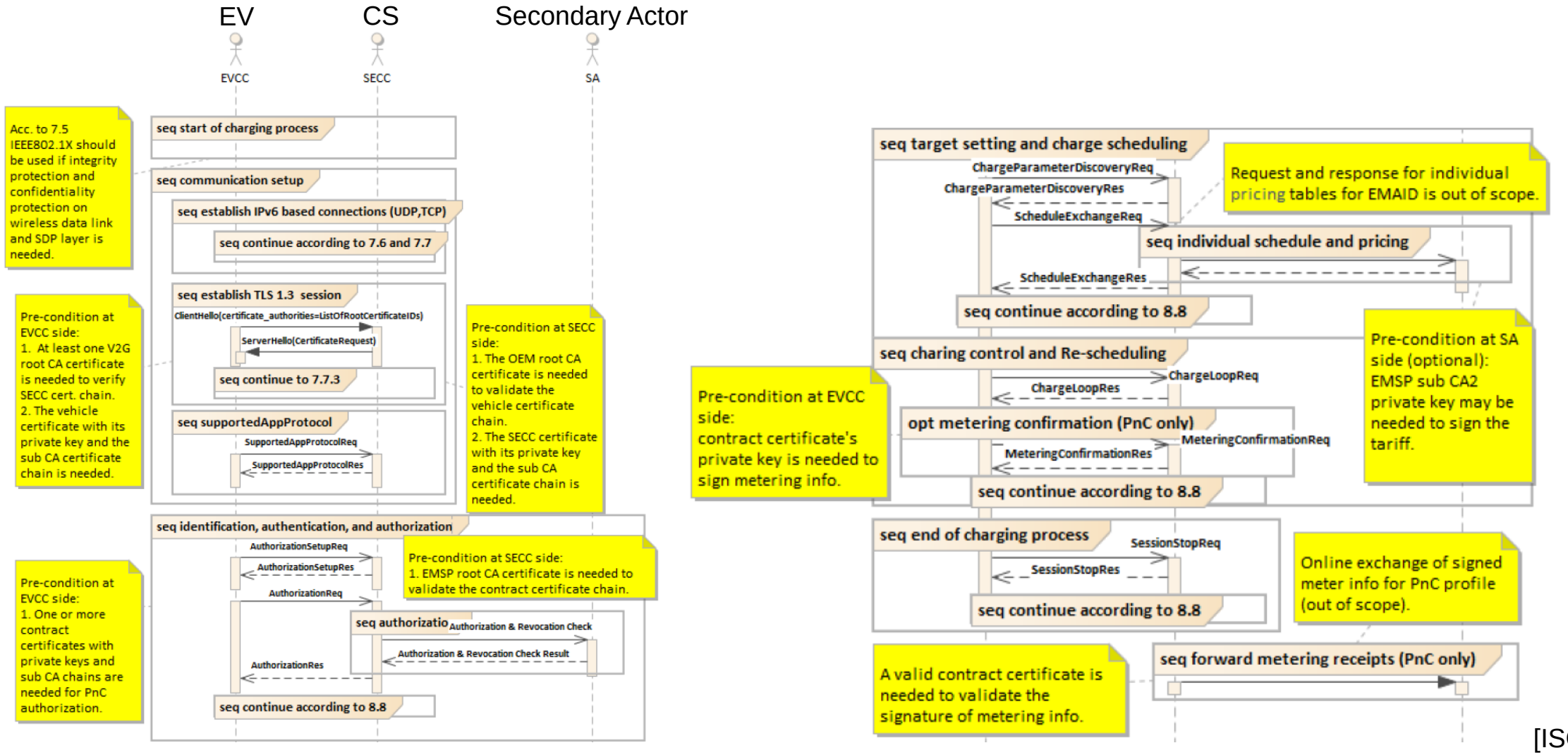
Véhicules routiers — Interface de communication entre véhicule et réseau électrique —

Partie 20: Exigences des couches réseau et application de 2ème génération

Reference number
ISO 15118-20:2022(E)

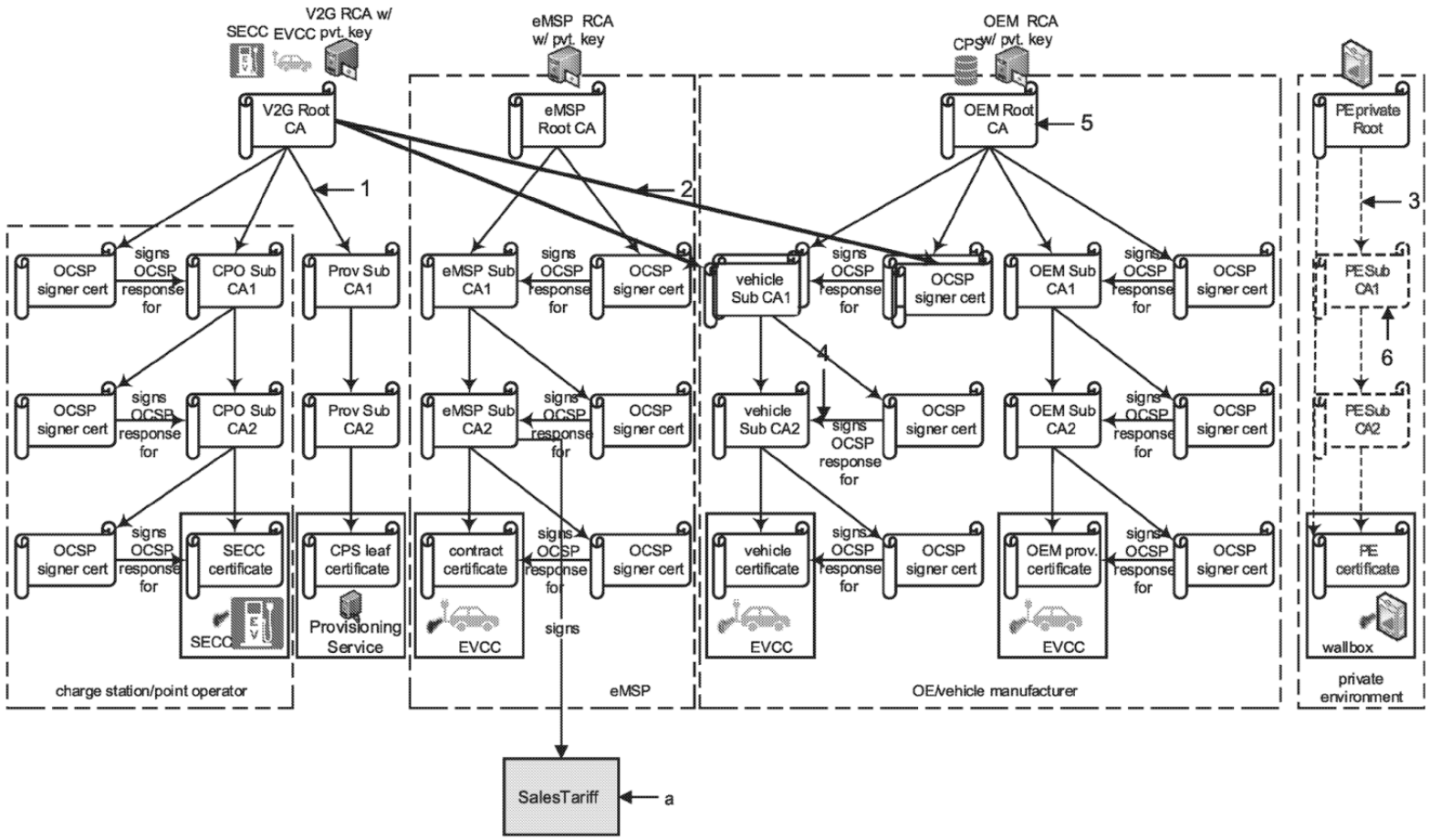
© ISO 2022

Security Concept of ISO 15118-20 – Overview II



[ISO22]

PKI and Certificates I



Example: ISO 15118-20 PKI and Certificate Structure (with cross signing) [ISO22]

Certificate field	Description
Version	Version of certificate (for 15118 it shall be v3 = 0x2)
Serial number	Unique number of certificate (within the domain of the issuer)
Signature algorithm	Used signature algorithm
Issuer	Entity, who has issued and signed the certificate
Validity period	Time period, in which the certificate is valid
Subject	Entity, to which the certificate is issued
Public key	Public key corresponding to a private key
Issuer UID	Optional issuer unique identifier
Subject UID	Optional subject unique identifier
Extensions	Additional attributes associated with entities or public keys or used to manage relationships between CAs
Signature	Signature of the certificate generated by the issuer

Basic Certificate Fields [ISO22]

CA: Certificate Authority
CPO: Charge Point Operator / CSO: Charging Station Operator
OCSP: Online Certificate Status Protocol
PE: Private Environment
UID: Unique Identifier

PKI and Certificates II

- V2G Root CA Certificate
  - Responsible trust anchor to verify SECC and CPS certificates
  - Alternative trust anchor to verify contract, vehicle, and OEM provisioning certificates
  - Multiple V2G root CAs with certificates may exist
- OCSP Signer Certificates
  - Used to verify signed OCSP responses with the certificate status
  - Support of SECC, contract, vehicle, and OEM provisioning certificate status validation
  - Trust anchor can be V2G or other root CA (see next slides)
- Sub-CA Certificates
  - Certificates of sub-CAs below a root CA
  - Used to verify leaf certificates or certificates of a second sub-CA

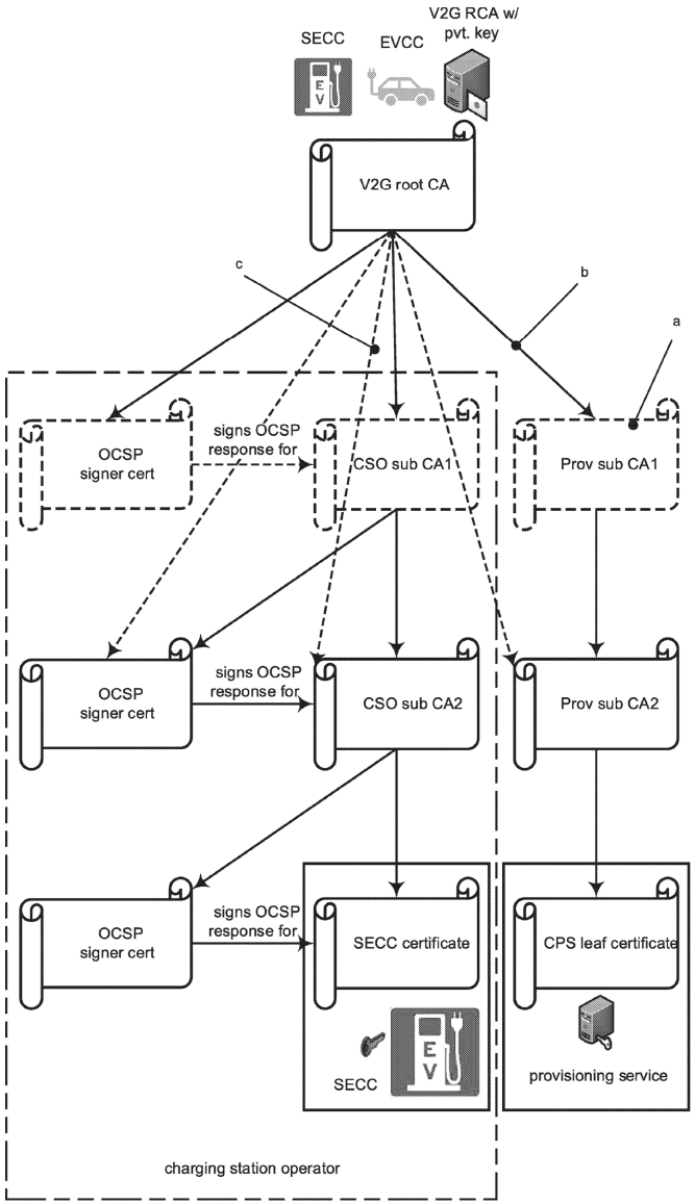
ISO 15118-20 certificate profiles			V2G root V2G
TbsCertificate	Version		2 ("2" indicates X.509v3)
	SerialNumber		(Positive integer)
	Signature	AlgorithmIdentifier	x
		algorithm	x id-Ed448
		parameters	-
	Issuer	Country	(x)
		Organization	x
		Organization unit	(x)
		Common name	x
		Domain component	(x)
	Validity	Validity	x (25 years)
		notBefore	x
		time	x (GeneralizedTime expressed in Greenwich Mean Time (Zulu) with format YYYYMMDDHHMMSSZ) [Actual time is CA discretionary]
		notAfter	x
		time	x (GeneralizedTime expressed in Greenwich Mean Time (Zulu) with format YYYYMMDDHHMMSSZ) [Actual time is CA discretionary]
	Subject	Country	(x)
		Organization	x
		Organization unit	(x)
		Common name	x
		Domain component	(x)
	SubjectPublicKey Info	AlgorithmIdentifier	x
		algorithm	x id-Ed448
		parameters	-
		SubjectPublicKey	x (BIT STRING)
	IssuerUniqueID		-
	SubjectUniqueID		-
	Extensions	AuthorityKeyIdentifier	-
		SubjectKeyIdentifier	x / nc id-ce-subjectKeyIdentifierx
		keyIdentifier	x (see [V2G20-1852])
		KeyUsage	x / c id-ce-keyUsage
		digitalSignature	0/1
		nonRepudiation (contentCommitment)	0/1
		keyEncipherment	0/1

Example: V2G Root CA Certificate

PKI and Certificates III

- SECC Certificate
  - Installed on CS during deployment
  - Used for TLS server authentication
  - Trust anchor is the V2G root CA certificate

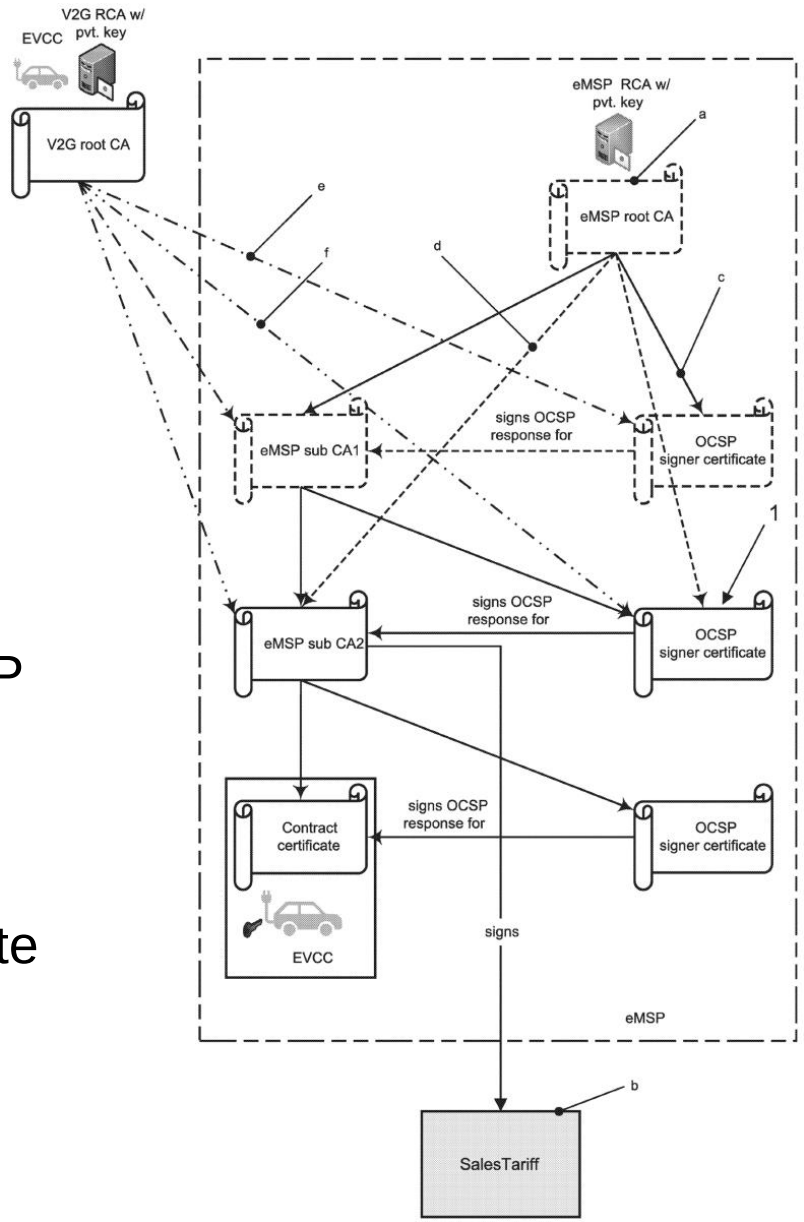
- CPS Leaf Certificate
  - Installed in CPS backend
  - Used to verify signed provisioning messages
    - CPS signs messages on behalf of an eMSP
  - Trust anchor is the V2G root CA certificate



PKI and Certificates IV

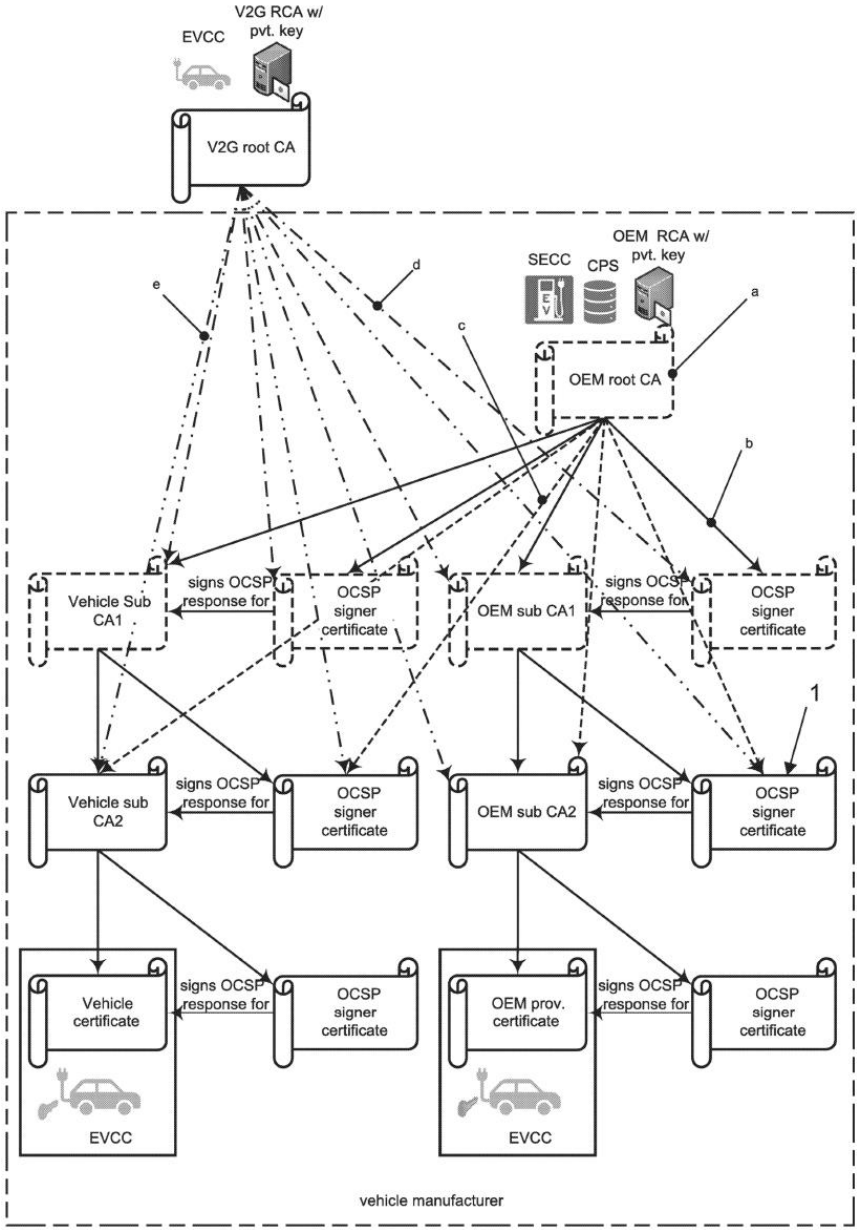
- eMSP Root CA Certificate
  - Used by CSs and secondary actors to verify contract certificates (along the certificate chain)
  - Trust anchor for contract certificate chain

- Contract Certificate
  - Generated after owner concludes contract with eMSP
  - Installed in EV during the first ISO 15118 session
  - Used by EV (on application layer) for authentication against SECC and secondary actors
  - Trust anchor is either eMSP or V2G root CA certificate



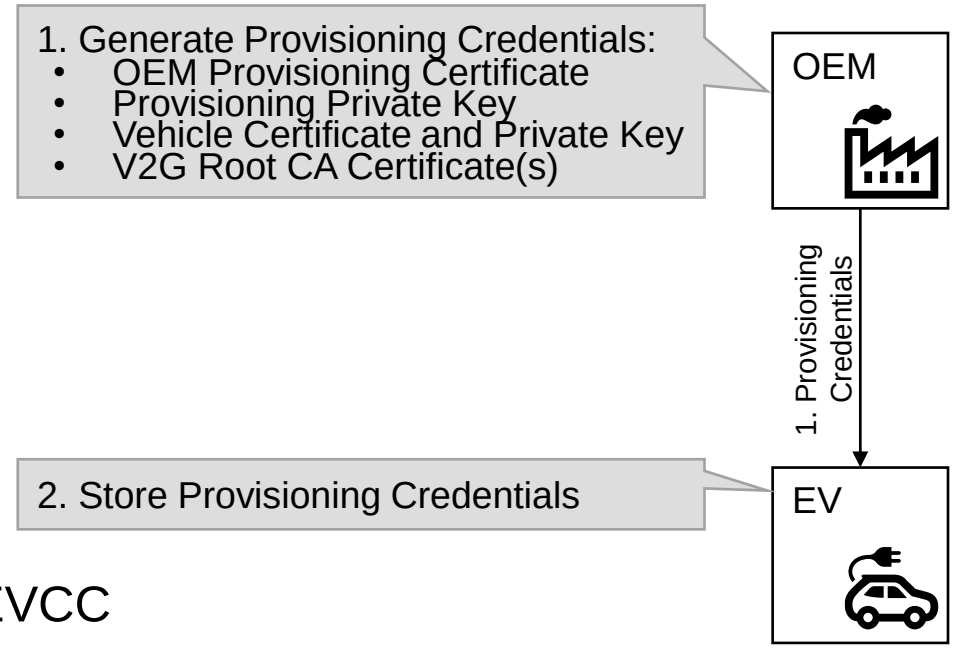
PKI and Certificates V

- OEM Root CA Certificate
  - Used by CSs and secondary actors to verify vehicle and OEM provisioning certificates
  - Trust anchor for vehicle and OEM provisioning certificates
- OEM Provisioning Certificate
  - Installed in EV during production
  - Used for EVCC authentication and installation of contract certificates
- Vehicle Certificate
  - Installed in EV during production
  - Used for TLS client authentication of the EVCC



Initial EV Certificate Provisioning

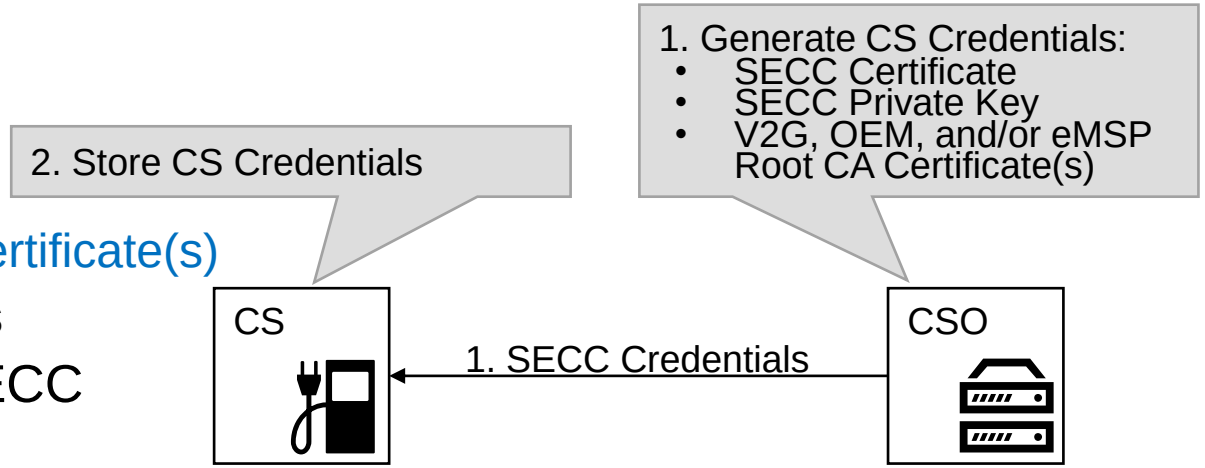
- EV Initialization
  1. OEM generates and sends to EV
     - Unique OEM Provisioning Certificate including
       - Provisioning Certificate ID (PCID)
       - Provisioning Public Key
       - Signature of Vehicle Sub-CA
       - OEM Sub-CA Certificates
       - …
     - Provisioning Private Key
     - Vehicle Certificate and Vehicle Private Key
     - V2G Root CA Certificate(s)
     - (Optionally) OCSP Signer Certificates
  2. Provisioning credentials are installed into the EVCC



- OEM Provisioning Certificate Pool (Optional)
  - Not part of ISO 15118, but defined by VDE [V19]
  - OEM sends OEM Provisioning Certificate to OEM Provisioning Certificate Pool
    - Enables eMSPs to access OEM Provisioning Certificates

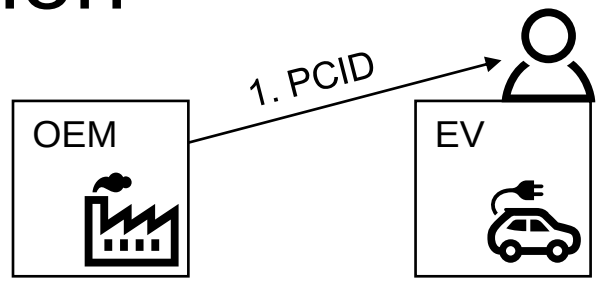
Initial CS Certificate Provisioning

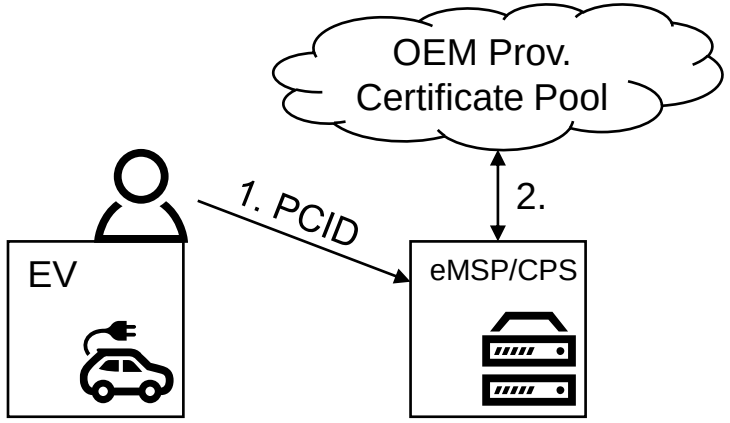
- CS Initialization
  1. CSO generates and sends to CS
     - SECC Certificate including
       - Supply Equipment Communications Controller Identifier (SECCID)
       - SECC Public Key
       - Signature of CSO Sub-CA
       - CSO Sub-CA Certificates
       - …
     - SECC Private Key
     - V2G, OEM, and/or eMSP Root CA Certificate(s)
     - (Optionally) OCSP Signer Certificates
  2. CS credentials are installed into SECC



Vehicle Delivery and eMSP Subscription

- Vehicle delivery
  1. OEM → Owner: PCID (e.g., printed on information sheet)
- eMSP Subscription
  1. Owner concludes contract with eMSP for charging services
     Owner → eMSP: PCID
  2. eMSP uses PCID to retrieve OEM Provisioning Certificate from OEM Provisioning Certificate Pool
  3. eMSP generates Contract Certificate Package
     - Contract Private Key is secured
       - Encrypted with AES-GCM-256
       - Symmetric session key
         - Generated with ephemeral-static Diffie-Hellman (DH)
         - Prov. Public Key is static DH Public Key of EV
     - CPS trusts eMSP and signs package so that EV can verify

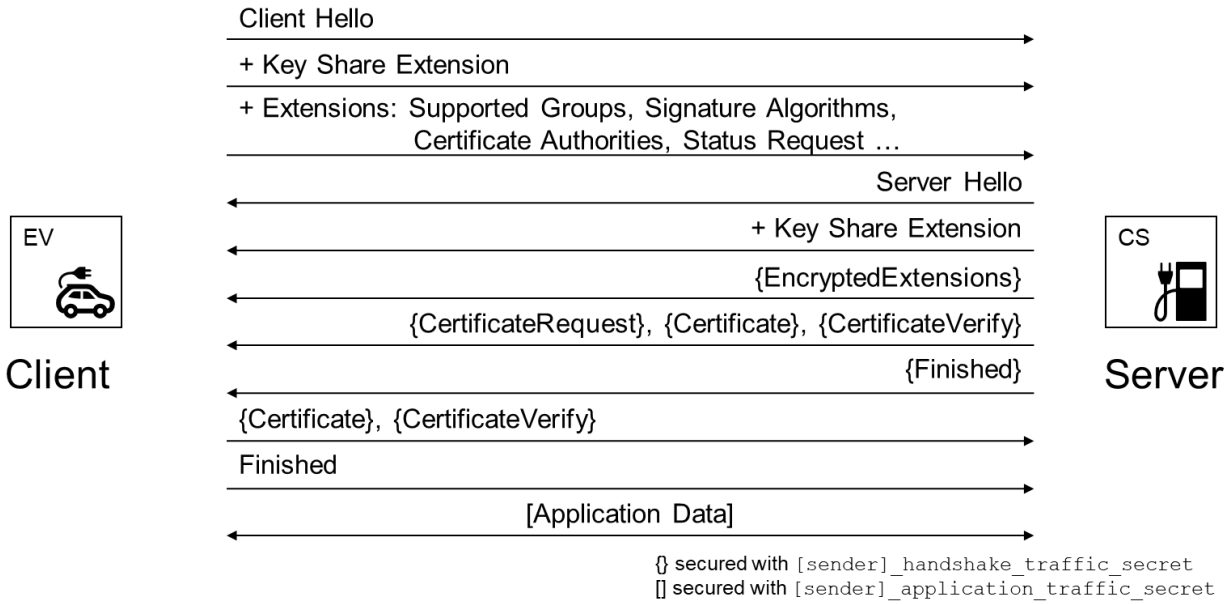




3. Generate Contract Certificate Package:
- Contract Certificate
  - E-Mobility Account Identifier (EMAID)
  - Contract Public Key
  - Signature of eMSP Sub-CA
  - eMSP Sub-CA Certificates
  - …
- Encrypted Contract Private Key
- Ephemeral DH Public Key of eMSP

Establishment of a TLS 1.3 Session

- EV initiates TLS 1.3 handshake
  - Negotiation of cipher suites, signature algorithms, groups etc.
  - Agreement on common V2G Root CA
  - EV can request OCSP status information via CS; CS directly via OCSP or CRL
  - EV uses Vehicle Certificate chain; CS uses SECC Certificate chain
- Session resumption `psk_dhe_ke` (only for Value Added Services VAS)

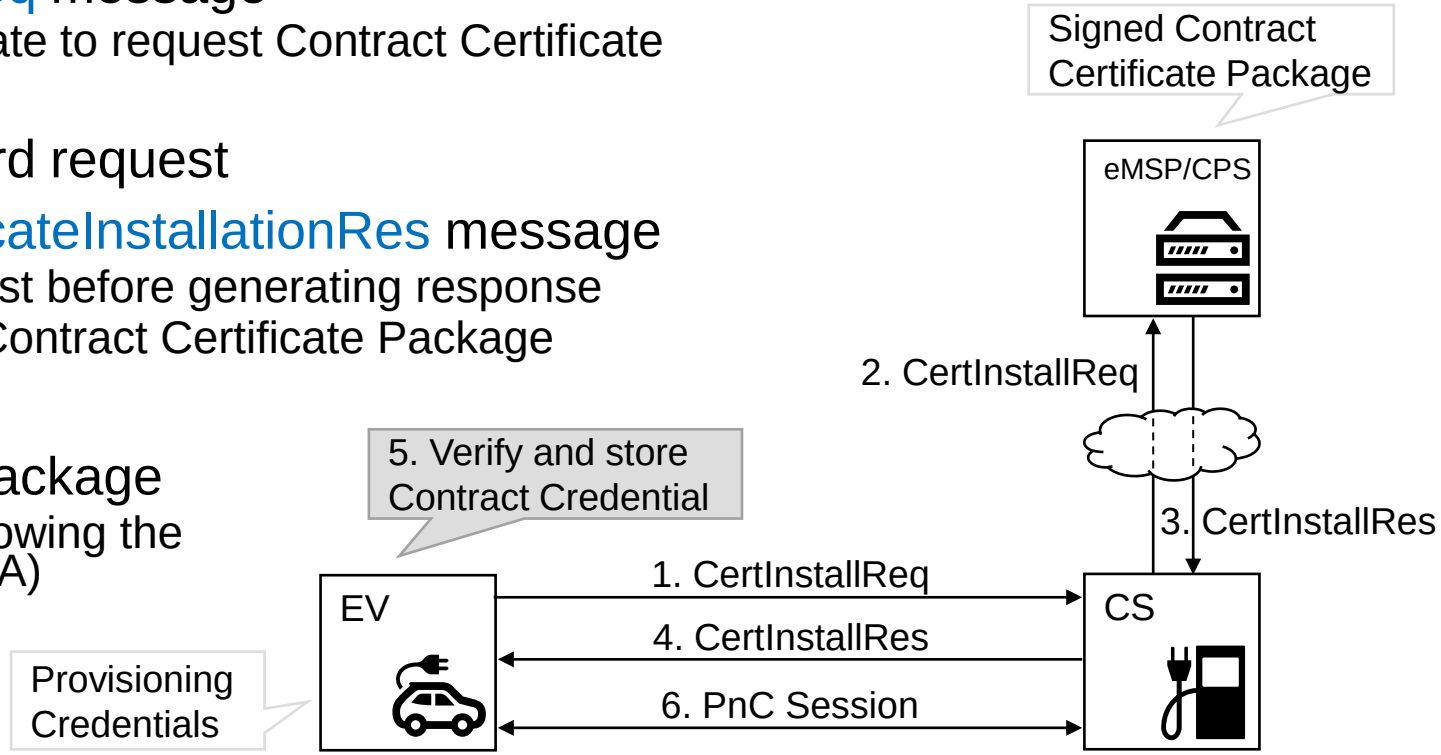


Cipher Suites	• `TLS_AES_256_GCM_SHA384` • `TLS_CHACHA20_POLY1305_SHA256`
Signature Algorithms	• `ecdsa_secp521r1_sha512` • `ed448`
Named Groups	• `secp521r1` • `x448`

Contract Certificate Installation

- Preconditions
  - EV stores Provisioning Credentials
  - Owner has subscribed to eMSP and signed Contract Certificate Package has been created
  - TLS session has been established between EV and CS

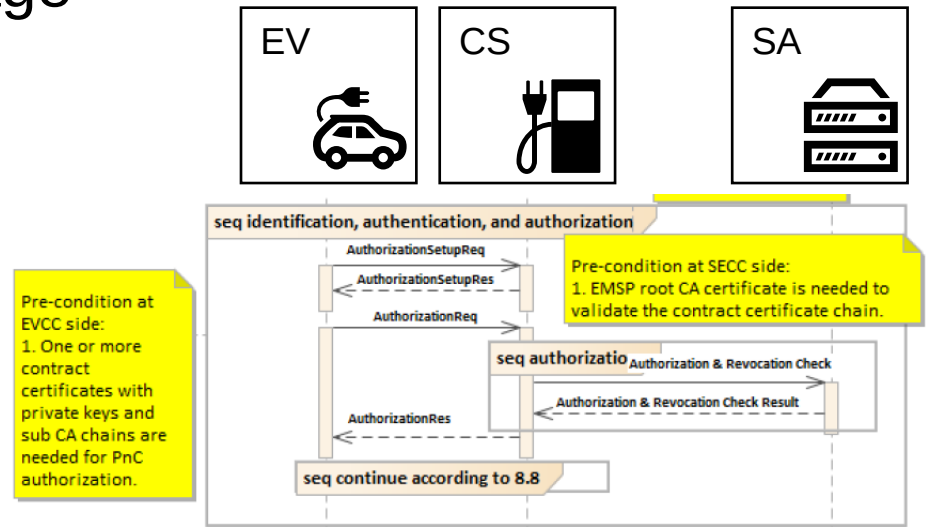
1. EV → CS: CertificateInstallationReq message
   - Message contains OEM Prov. Certificate to request Contract Certificate
   - Signed with Provisioning Private Key
2. CS → CSO → eMSP/CPS: Forward request
3. eMSP/CPS → CSO → CS: CertificateInstallationRes message
   - eMSP/CPS verifies signature of request before generating response
   - Response message contains signed Contract Certificate Package
4. CS → EV: Forward response
5. EV receives Contract Certificate Package
   - EV validates signature of CPS (by following the certificate chain up to the V2G Root CA)
   - EV calculates DH session key and decrypts Contract Private Key



PnC Authentication / Authorization

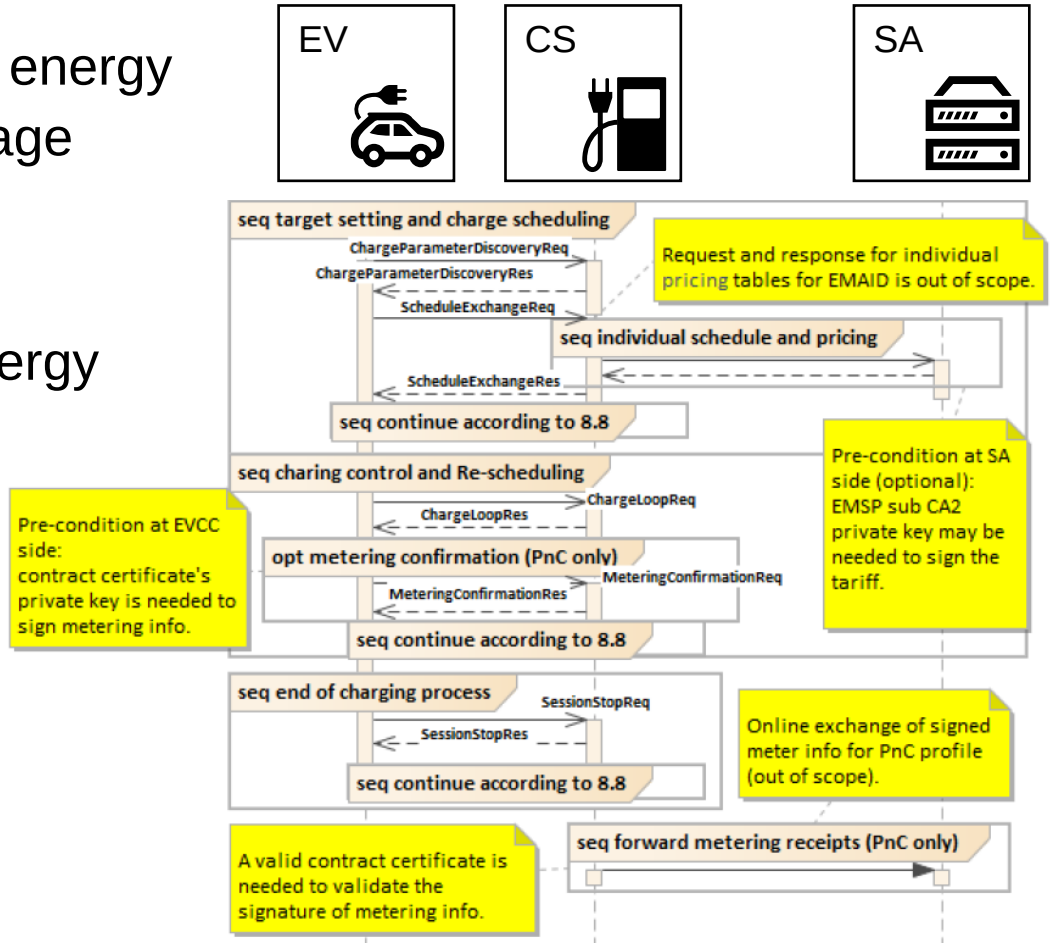
- Preconditions
  - EV stores Contract Credentials
  - TLS session has been established between EV and CS

1. EV → CS: AuthorizationSetupReq message
   - EV initiates its authentication / authorization for PnC
2. CS → EV: AuthorizationSetupRes message
   - Contains a random challenge
3. EV → CS: AuthorizationReq message
   - Contains XML signature with Contract Private Key over the challenge
4. CS → EV: AuthorizationRes message
   - Sent after successful verification of signature, certificate chain, and certificate status



Further Application Layer Security

- Metering Confirmation
  - EV acknowledges the amount of charged energy
  - EV signs MeteringConfirmationReq message with Private Contract Key
- Charging Parameter and Schedule
  - EV and CS negotiate optimal supply of energy that corresponds to the customer needs
  - SA / eMSP signs tariff information in ChargeParameterDiscoveryRes message with Private eMSP sub-CA 2 Key
- …



Security Issues of ISO 15118-20

- Cryptographic algorithm issues
  - Still no cryptographic agility, fixed cipher suites …
  - No support of post-quantum cryptography
  - No migration strategies to new cryptographic algorithms
  - No PFS for contract certificate installation with ephemeral-static DH
- Hardware security for protecting cryptographic keys in EV and CS still only recommended
  - However, optional use of TPM 2.0 now part of the standard (based on [FKK20a])
  - Key generation only in backend and not in EV's HSM (cf. [FKK20b, FKK20c, FKK20d])
- Backwards compatibility to Edition 1 may enable downgrade attacks
- Missing requirements for PKI and certificate management (cf. aspects of [CDE19])
- Physical layer attacks
  - Wireless charging and communication via Wi-Fi enable wireless attacks such as jamming
  - Attacks on PLC [BM19, KBS22]
- No formal security proofs
- No privacy-preserving measures defined

Summary

Summary

- Electric mobility will be an important part of our mobility
- Many attacks may be possible
  - Attacks on billing
  - Attacks on privacy
  - Attacks on the power grid
  - Attacks on the EV
  - …
- Standards such as ISO 15118 already include security
  - New research results proposed in [FKK20a] have been integrated into new ISO 15118-20
- Security and privacy improvements still required

Outlook

- Future versions of standards should include new research results, e.g.,
  - Credential generation and storage within HSM / TPM [FKK20b, FKK20d]
  - Cryptographic agility and support of post-quantum cryptography [KKL23]
  - Privacy-preserving charging and billing [ZSZK18, KLK22]
  - Ensuring the trustworthiness of EVCC and BMS [FKKZ20c]
  - Securing CPs [KKZ19]
  - …
- Additional research required
- We are working on it ;-)

Source: Gregor Schuster for ACSD

Literature

Literature I

[BM19] R. Baker and I. Martinovic. Losing the Car Keys: Wireless PHY-Layer Insecurity in EV Charging, 28th USENIX Security Symposium, 2019

[BVW18] K. Bao, H. Valev, M. Wagner, and H.Schmeck. A threat analysis of the vehicle-to-grid charging protocol ISO 15118, Computer Science – Research and Development 33, 3–12, 2018

[CDE19] ChargePoint, DigiCert, and Eonti. Practical Considerations for Implementation and Scaling ISO 15118 into a Secure EV Charging Ecosystem. https://www.chargepoint.com/files/15118whitepaper.pdf, 2019

[Dal17] M. Dalheimer. Ladeinfrastruktur für Elektroautos: Ausbau statt Sicherheit - Warum das Laden eines Elektroautos unsicher ist, 34C3, 2017

[EC11] European Commission. Roadmap to a Single European Transport Area – Towards a competitive and resource efficient transport system, 2011

[El17] ElaadNL. EV Related Protocol Study, Version 1.1, 2017

[El18] ElaadNL. Exploring the public key infrastructure for ISO 15118 in the EV charging ecosystem, Version 1.0, 2018

[FKK20a] A. Fuchs, D. Kern, C. Krauß, and M. Zhdanova. TrustEV: Trustworthy Electric Vehicle Charging and Billing, SAC SEC - Computer Security, 2020

[FKK20b] A. Fuchs, D. Kern, C. Krauß, and M. Zhdanova. HIP: HSM-based Identities for Plug-and-Charge, 13th International Conference on Availability, Reliability and Security (ARES), 2020

[FKK20c] A. Fuchs, D. Kern, C. Krauß and M. Zhdanova. Securing Electric Vehicle Charging Systems through Component Binding, 39th International Conference on Computer Safety, Reliability and Security (SAFECOMP), 2020

[FKK20d] A. Fuchs, D. Kern, C. Krauß, M. Zhdanova, and R. Heddergott. HIP-20: Integration of Vehicle-HSM-Generated Credentials into Plug-and-Charge Infrastructure, ACM Computer Science in Cars Symposium (CSCS), 2020

[Hu18] Hubject. Open InterCharge Protocol (OICP) Version 2.2, 2018

Literature II

[ISO14] ISO. ISO 15118-2:2014 Road vehicles - Vehicle-to-Grid Communication Interface - Part 2: Network and application protocol requirements, 2014

[ISO22] ISO. ISO 15118-20:2022 Road vehicles - Vehicle to grid communication interface - Part 20: 2nd generation network layer and application layer requirements, 2022

[KBS22] S. Köhler, R. Baker, M. Strohmeier, and Ivan Martinovic. Brokenwire: Wireless Disruption of CCS Electric Vehicle Charging, arXiv preprint arXiv:2202.02104, 2022

[KK21] D. Kern, C. Krauß. Analysis of E-Mobility-based Threats to Power Grid Resilience, ACM Computer Science in Cars Symposium (CSCS), 2021

[KKL23] D. Kern, C. Krauß, T. Lauser, N. Alnahawi, A. Wiesmaier, R. Niederhagen. QuantumCharge: Post-Quantum Cryptography for Electric Vehicle Charging. 21st International Conference on Applied Cryptography and Network Security (ACNS). Springer. 2023.

[KLK22] D. Kern, T. Lauser, and C. Krauß. Integrating Privacy into the Electric Vehicle Charging Architecture, PoPETs, vol. 2022, no. 3, 2022

[NE15] NEMA. EVSE 1.2, 2015

[NPE17] German National Platform for Electric Mobility (NPE). The German Standardisation Roadmap Electric Mobility 2020, April 2017

[OCA18a] Open Charge Alliance. Improved security for OCPP 1.6-J, v1.0 FINAL, 2018

[OCA18b] Open Charge Alliance. OCPP 2.0, 2018

[SBF21] SPD, BÜNDNIS 90/DIE GRÜNEN, FDP. Mehr Fortschritt wagen Bündnis für Freiheit, Gerechtigkeit und Nachhaltigkeit - Koalitionsvertrag 2021 - 2025

[Sch18] Schneider Electric. Security Notification – EVLink Parking, https://www.se.com/ww/en/download/document/SEVD-2018-354-01/

[V19] VDE. Handling of certificates for electric vehicles, charging infrastructure and backend systems within the framework of ISO 15118. VDE-AR-E 2802-100-1:2019-12, .2019

[ZSZK18] D. Zelle, M. Springer, M. Zhdanova and C. Krauß. Anonymous Charging and Billing of Electric Vehicles, 13th International Conference on Availability, Reliability and Security (ARES), 2018